

## **1. Privacy, GDPR and Data Minimisation**

### **Data Collection**

The AI Failures Museum system uses Django's built-in User model to handle accounts. Our system collects the following data:

#### **User Account Data collected:**

- Username
- Email address
- Password
- First Name
- Last Name
- Account creation timestamp
- Last login timestamp
- Account status flags

#### **When visitors post comments on exhibits, the system collects:**

- Author Name
- Comment text
- Timestamp when posted
- Which exhibit they commented on
- If the comment was in reply to another comment

We do not collect any sensitive information such as health, race, ethnicity, political opinions, religious, payment or location tracking details.

We are processing this data based on user consent. When an account is created the user will agree to let us store this information.

## **Data Storage and Security**

**Database:** All data is stored in a SQLite3 database file which has restricted file permissions so only the application can access the file.

**Password Security:** Passwords are hashed using Django's hashing algorithm and is a lot more of a secure way than trying to encrypt them. Even if somebody were able to get access to our database, they would not be able to read the passwords as they couldn't reverse the hash to get the actual passwords.

**Users have the following rights, implementable via Django's admin interface:**

- Access: View their data through Django admin
- Rectification: Edit username, email, first name and last name
- Erasure: Delete account via Django admin

## **2. Acceptable Use and safety of Gamification**

Our system has immediate feedback gamification for our quizzes. Our database has 33 quiz questions across all our exhibits.

### **Quiz Scoring and Feedback**

#### **When users complete a quiz they receive:**

- Overall score displaying how many questions they got right out of the attempted questions while showing a percentage score too
- Colour coded feedback (Green for correct and red for incorrect)
- Question by question breakdown
- Explanations for each question to help aid learning and understanding
- Option to retake quizzes
- A link back to the exhibit to review content

### **Quiz Design Principles**

The quiz feedback has been designed so that it is supposed to be educational rather than competitive:

- No time limits on the quiz which ensures self-paced learning
- Scores are stored privately per user in the database and are not publicly displayed to other users. Users can view all their own quiz scores on their profile page.
- Users see immediate feedback
- The users have the option to retake the quiz
- Wrong answers do not count against the user

This approach focuses on the learning rather than competition which ensures that users are taking the tests to improve their understanding, since no scores are reflected users are more incentivised to attempt quizzes fairly as there are no repercussions and there are detailed explanations for every question regardless if the user got the question right or wrong.

### **3. Risks of Misinformation and Misleading Claims**

In our database each exhibit includes:

- Failure description
- Contributing factors
- Lessons learned
- Supporting artefacts
- Timeline information

Our exhibits cover multiple sectors including environmental management, agricultural surveillance, fintech and lending, public health and smart city monitoring, autonomous transportation, conservation biology, real estate and legal tech, logistics and healthcare and civil engineering infrastructure.

Since we are presenting real or realistic AI failure cases there are some risks that are attached:

AI failure case studies risk:

- Oversimplification of complex technical issues
- We could get factual details wrong
- We could accidentally damage someone's reputation if we are not careful about how we present real incidents
- Users might misunderstand how AI actually works
- We could make AI seem scarier or worse than it really is

#### **How we are dealing with this:**

Only users that have curators permissions can create or edit exhibits through Django's admin interface. With every change being logged so we can see who changed what and when.

For real-world incidents that were publicly reported, we name the company and present facts as a neutral. For more sensitive cases, we anonymise them to avoid reporting sensitive information.

We never name individual developers or engineers, never include personal information and avoid using inappropriate language. We also do not present speculation as if it's fact.

If we get something wrong, the Django admin log lets us track changes and update the exhibits.

The system has a commenting system where visitors can discuss exhibits. The comments are:

- Public and visible to all users
- Limited to 2,000 characters to prevent potential spam

#### **4. Accessibility and Inclusion**

Our project will aim to make sure everyone can use our website, including people with disabilities. We also want to make sure our content represents different contexts and doesn't exclude certain groups.

Django's form system does some of the basics for us automatically. Form fields come with proper labels that screen readers can understand, error messages get linked to the right fields and the admin interface has basic keyboard navigation built in.

All exhibits are text based with images that are optional and the exhibits can be understood without them. This means that users can access all the important educational content without missing anything if they didn't have the images.

We are aiming to include AI failures from different contexts and fields, not just focusing on big tech companies. We want the content to be relevant to different industries and geographic regions such as flooding failures that could happen in the UK, healthcare issues that affect diverse populations and international incidents showing global AI impacts.

There is no premium or pay to view features which ensures that everyone can access everything for free.

## **5. Security Controls**

We are using Django's built-in authentication system. Passwords are hashed which is what Django does by default and exceeds security recommendations.

Django's `AUTH_PASSWORD_VALIDATORS` is currently set to an empty list, meaning no password complexity rules are enforced at signup. This is a known limitation flagged for Sprint 2. However, all passwords are still stored securely using Django's built-in hashing algorithm regardless of this setting.

### **We have three user types:**

- Regular visitors - can browse exhibits and view quizzes
- Curators - can create and edit exhibits through Django admin
- Admins - full access to everything

Django admin automatically enforces these permissions, so visitors cannot access curator tools even if they try to go to those URLs directly.

Django's admin log records all admin actions - creating exhibits, editing them, deleting things and changing user permissions. Each entry includes who did it, what they did and when. Only superusers can see these logs. Passwords are never logged.

## **6. Conclusion: Ethics Approval Decision**

We have concluded that a formal ethics approval is not required because:

### **1. Target Audience**

- University students (18+) and professionals
- No vulnerable groups
- Voluntary participation

### **2. Minimal Data collection**

- Only basic account information: username, email, hashed password, optional names
- No sensitive information is stored

### **3. Minimal behaviour tracking**

- We do not track which exhibits users view or how long they spend
- We store only users best quiz score per exhibit
- No third-party cookies or tracking services

### **4. Low Risk Educational Purpose**

- Learning from AI failures to improve practice
- All changes logged in admin log for accountability
- Curator oversight of all exhibit content

### **5. Standard Security Practices**

- Role-based access control with three user types
- Password Hashing

### **6. No Third-Party Data Sharing**

- All data stored locally in SQLite3 database
- No external analytics

**When We Would Need Ethics Approval:**

If our project evolved to include the following:

- Research Data Collection
- Demographic Surveys
- External data sharing
- Commercial use

Given that our project does not currently implement any of the above we believe that a formal ethics approval is not required